

Informe de vulnerabilidades del sistema académico

Fecha: 21 de septiembre de 2026 · Zona horaria: America/Guayaquil

Clasificación: uso interno. Contiene información técnica que facilita localizar debilidades; compartir únicamente con responsables del sistema.

Versión revisada: rama `main`, commit `b9521f2c`. Se incluyó el archivo local `backend/sql/2026_09_20_auditoria_ddl_tolerante.sql`, todavía sin versionar. El sitio IIS examinado publica `frontend/dist`; el backend activo es Python/FastAPI. El árbol Angular se evaluó como componente separado, sin evidencia de despliegue en este sitio.

1. Resultado ejecutivo

Riesgo técnico observado: ALTO. Se documentan 14 hallazgos agrupados: 9 de prioridad alta y 5 de prioridad media. Las prioridades son una valoración contextual de impacto y exposición, no puntuaciones CVSS calculadas ni una certificación de cumplimiento. No se confirmó una explotación crítica del sistema en producción. El análisis de componentes sí contiene un aviso calificado como crítico por su fabricante, con condiciones de explotación local no demostradas.

Los riesgos principales permiten elevar privilegios desde ciertos perfiles internos, acceder a documentación ajena con una sesión válida, suplantar la identidad en evaluaciones y deducir contraseñas institucionales. La conexión académica a SQL Server se observó sin cifrado y con privilegios `sysadmin`. El estado de cierre de sesión no se comparte entre los dos workers configurados.

Hay controles efectivos: TLS 1.2 y 1.3, certificado verificado, cookies protegidas, JWT firmado con validaciones, errores internos enmascarados, rutas que rechazan sesiones ausentes, SQL parametrizado en los flujos muestreados y validaciones de archivos. Estos controles no compensan los problemas de autorización y configuración descritos.

Esta revisión no aplicó correcciones, no modificó cuentas, matrículas, calificaciones, servicios, dependencias productivas ni configuración. Solo se crearon los documentos y evidencias del informe. No se realizaron ataques de carga, intentos masivos de contraseña, lectura de documentos personales ni creación de usuarios reales.

2. Alcance, método y límites

Se revisaron autenticación, sesiones, permisos por rol, administración de usuarios, evaluaciones docentes, ingreso directo por Excel, credenciales, descarga y carga de documentos, integraciones Moodle/Graph y configuración IIS/SQL. La revisión de código fue selectiva y dirigida a estos flujos; no equivale a probar todos los endpoints y combinaciones de perfiles.

Se ejecutaron consultas SQL de metadatos y configuración, lectura de configuración efectiva con valores sensibles omitidos, solicitudes HTTP/HTTPS de bajo impacto y cuatro negociaciones TLS. Se hicieron pruebas locales con identidades ficticias, dobles de base de datos y almacenes de sesión en memoria. Ningún token ficticio se envió al servidor productivo.

Se ejecutó `npm audit` para los dos frontends y `pip-audit 2.10.1` desde un entorno temporal aislado sobre el inventario Python instalado y los requisitos directos. Los avisos se contrastaron con fuentes oficiales; pueden cambiar tras esta fecha. Se deduplicaron identificadores equivalentes CVE/GHSA/PYSEC en Python.

Las 27 pruebas seleccionadas de seguridad y 13 subpruebas pasaron. Son pruebas existentes de controles concretos; no constituyen prueba de ausencia de vulnerabilidades. La simulación adicional demostró los fallos de separación de roles, emisión de token de evaluación y revocación entre procesos, sin utilizar registros reales.

No se ejecutaron Gitleaks, Bandit, Semgrep o CodeQL en esta sesión; se revisó la existencia de flujos CI para algunos de estos controles, pero no su último resultado remoto. No se auditó íntegramente el historial Git, el sistema operativo, SQL Server por CVE, el código del servidor Moodle, el tenant Microsoft 365 ni [backend-dotnet](#). La accesibilidad desde Internet fuera de este servidor no se comprobó desde una red independiente. No se certifica cumplimiento ISO ni legal mediante este escaneo.

3. Resumen priorizado

ID	Prioridad	Punto a corregir
V01	Alta	Administración de usuarios permite elevar privilegios
V02	Alta	Descargas sin autorización sobre cada documento
V03	Alta	Evaluación docente acredita identidad solo mediante cédula
V04	Alta	Contraseñas institucionales predecibles y reutilizadas
V05	Alta	Persistencia y aceptación de contraseñas en texto claro
V06	Alta	Cuenta SQL sysadmin y proceso bajo SYSTEM
V07	Alta	Conexión académica SQL sin cifrado
V08	Alta	Revocación de sesiones aislada por worker
V09	Media	Pérdida silenciosa de auditoría DDL
V10	Media	Análisis antimalware desactivado y carga directa sin verificación equivalente
V11	Media	Configuración de desarrollo, backend HTTP alternativo y ausencia de HSTS
V12	Alta	Dependencias Python instaladas con avisos conocidos
V13	Media	Dependencias vulnerables en el frontend Angular legado
V14	Media	Secreto de sesión compartido con integración externa

4. Hallazgos y criterios de corrección

V01. Elevación de privilegios desde administración de usuarios

Prioridad alta · OWASP A01 · Confirmado por código y prueba sintética.

[backend/app/routers/sisacademico_admin.py:22](#) permite a ADMINISTRADOR, ACADEMICO y RECTOR utilizar el editor. El endpoint genérico de creación en la línea 6061 deriva la sección `usuarios` a `_create_usuario_sis` sin autorización administrativa adicional. El campo `tp_us` es aceptado en la línea 6008 y el perfil predeterminado es 1; [backend/app/services/auth.py:24](#) lo interpreta como administrador. La edición genérica también permite modificar el perfil.

Una simulación con usuario académico y base de datos ficticia aceptó la solicitud y produjo una inserción con perfil administrador. No se creó ninguna cuenta real. Una cuenta académica comprometida podría obtener administración total mediante la API aunque la pantalla esté oculta.

Recomendación: restringir las operaciones de usuarios y roles a administradores, controlar cada sección en el servidor y prohibir asignaciones de privilegios superiores al alcance autorizado. Criterio de cierre: pruebas de creación y cambio de perfil desde Académico/Rector devuelven 403, sin escrituras, y la operación administrativa autorizada continúa funcionando.

V02. Acceso a documentos ajenos mediante la ruta de archivos

Prioridad alta · OWASP A01 · Confirmado por código; no se descargó documentación ajena.

`backend/app/main.py:302` sirve `/uploads/{file_path:path}` a cualquier usuario autenticado. Comprueba la contención de ruta y la existencia, pero no propietario, rol o matrícula del documento. Hay productores de esas URLs en `routers/carnet.py:515`, `routers/titulos_registrados.py:102` y `routers/preinscription.py:2537`. Se observaron archivos reales en las carpetas de carnés y títulos sin leer su contenido. Algunas rutas futuras de preinscripción son predecibles; no se presupone que todas las actuales lo sean.

Un usuario con sesión y conocimiento de la URL podría obtener documentos de otra persona. La respuesta anónima 401 comprobada no evita este acceso entre usuarios autenticados.

Recomendación: descargar mediante un identificador ligado a un registro y verificar propiedad o función autorizada antes de servirlo. Criterio de cierre: un estudiante no puede descargar el archivo de otro; docentes y administrativos solo acceden al alcance asignado. Mantener el control de rutas y las cabeceras `no-store` existentes.

V03. Suplantación en evaluación docente

Prioridad alta · OWASP A07/A01 · Confirmado con identidad y base de datos simuladas.

`backend/app/routers/teacher_evaluation.py:5000` publica `/identity/{cedula}`. El conocimiento de una cédula de diez dígitos permite solicitar identidad, cursos y un token de evaluación de treinta minutos, emitido alrededor de la línea 5121. No se exige contraseña, sesión, SSO u OTP para acreditar al titular. Las consultas y envíos posteriores aceptan ese token en las líneas 5140, 5164, 5199 y 5277.

El límite de consultas, la validación de matrícula y la prevención de duplicados no prueban identidad. Un tercero podría consultar información y responder primero en nombre del titular. La simulación confirmó la emisión y aceptación del token sin sesión; no se enumeraron personas ni se enviaron evaluaciones productivas.

Recomendación: autenticar con SSO, sesión institucional u OTP antes de emitir el token y vincularlo al propósito autorizado. El anonimato de las respuestas puede mantenerse después de autenticar. Criterio de cierre: conocer solo la cédula no entrega información individual ni habilita votos.

V04. Contraseñas institucionales predecibles

Prioridad alta · OWASP A07/A06 · Confirmado por código.

`backend/app/routers/credential_generator.py:256` deriva la clave de datos personales y del año, sin aleatoriedad criptográfica. Las líneas 910 y 1148 desactivan el cambio inicial obligatorio en Microsoft 365 y Moodle. La línea 1232 reutiliza la clave entre ambos servicios; `services/direct_admission_credentials.py:308` lleva esta política al ingreso por Excel.

La combinación hace deducible y duradera una credencial que puede abrir dos servicios. No se calcularon ni probaron contraseñas reales. La ausencia de caducidad periódica, por sí sola, no es el hallazgo: lo es mantener claves iniciales predecibles y compartidas.

Recomendación: claves iniciales aleatorias, entrega segura, cambio obligatorio al primer acceso y MFA/SSO donde corresponda. Revisar y restablecer de forma controlada las claves ya emitidas. Criterio de cierre: la misma información personal no reproduce la contraseña, no se reutiliza entre servicios y no puede mantenerse la clave temporal sin cambio.

V05. Contraseñas locales almacenadas en texto claro

Prioridad alta · OWASP A04/A07 · Confirmado por código y escritura simulada.

`backend/app/routers/sisacademico_admin.py:5993` conserva la contraseña recibida y la inserta en `USUARIO_SIS` alrededor de la línea 6049. La creación docente en las líneas 5854 y 5866 y actualizaciones en `routers/institutional_email.py:522` también mantienen valores literales. `core/security.py:80` admite comparación directa cuando el valor no es Argon2 y la compatibilidad heredada está activa. Se comprobó

`AUTH_LEGACY_PLAINTEXT_ENABLED=true` en la configuración efectiva.

La exposición de tablas o respaldos puede revelar claves utilizables. No se extrajeron hashes o contraseñas de la base real ni se cuantificaron usuarios afectados. La simulación confirmó que una contraseña ficticia llega al INSERT sin hash.

Recomendación: migrar todos los caminos de autenticación y escritura a Argon2id, revisar longitudes de columnas y compatibilidad de aplicaciones heredadas, y deshabilitar el modo de texto claro al completar la migración. El archivo cifrado de credenciales externas es una función diferente y requiere su propia política de acceso y retención.

Criterio de cierre: todas las altas/cambios guardan hashes adecuados y la autenticación rechaza valores literales heredados sin dejar usuarios sin acceso durante la transición.

V06. Privilegios excesivos del servicio y de SQL

Prioridad alta · OWASP A02/A01 · Confirmado en configuración y consultas de metadatos.

La conexión académica utiliza la cuenta `sa`; `IS_SRVROLEMEMBER('sysadmin')=1` e `IS_ROLEMEMBER('db_owner')=1`. `backend/app/services/db.py:144` construye esa conexión con las credenciales configuradas. La tarea programada `intec_sis_aca_backend` ejecuta el backend como `SYSTEM`, nivel `Highest`.

Estos permisos amplían el impacto de cualquier fallo de aplicación hasta el servidor o la base completa. No se demostró ejecución remota de código ni se afirma que los puertos de SQL estén accesibles desde cualquier red.

Recomendación: identidad de servicio dedicada con ACL mínimas y usuario SQL de aplicación limitado; separar la cuenta de migraciones de la usada en solicitudes web. Criterio de cierre: la cuenta productiva no pertenece a `sysadmin/db_owner`, el backend no se ejecuta como `SYSTEM` y las operaciones autorizadas pasan pruebas de regresión.

V07. Tráfico SQL académico sin cifrado

Prioridad alta · OWASP A04 · Confirmado en una conexión real.

Configuración efectiva: `DB_ENCRYPT=no`, `DB_TRUST_CERT=yes`. La consulta `sys.dm_exec_connections` para la conexión de revisión devolvió `encrypt_option=FALSE`. La evidencia se refiere a la base académica principal; no se extrapola automáticamente a todas las conexiones auxiliares. Referencia: `backend/app/services/db.py:15` y `:144`.

Datos y consultas de esa conexión pueden quedar expuestos a quien consiga observar el trayecto de red. El HTTPS del navegador no cifra este salto backend-base de datos.

Recomendación: certificado SQL válido para el nombre usado por la aplicación, `Encrypt=yes` y `TrustServerCertificate=no`, con prueba previa de conectividad. Criterio de cierre: `encrypt_option=TRUE` y un certificado inválido o de nombre incorrecto provoca rechazo. Microsoft: [cifrado ODBC](#).

V08. Revocación de sesión y límites aislados entre procesos

Prioridad alta para sesiones; media para límites · OWASP A07 · Confirmado por configuración, código y simulación.

Se observó `rate_limit_backend=memory` y dos workers configurados en el proceso principal. `backend/app/core/session_revocation.py:21` guarda revocaciones en un diccionario local cuando no usa Redis; `core/rate_limit.py:221` selecciona también memoria local.

En una prueba con dos almacenes aislados, la sesión ficticia revocada en uno seguía sin revocar en el otro. El límite de intentos tampoco se compartió. Una cookie cerrada puede seguir aceptándose en otro worker hasta su expiración; los reinicios eliminan el estado. La duración configurada observada fue de 480 minutos.

Recomendación: almacén Redis compartido y protegido para todos los procesos, con comportamiento de fallo definido e invalidación controlada de sesiones al migrar. Criterio de cierre: cerrar sesión impide reutilizar la cookie contra cualquier worker; los contadores de intentos son únicos y persisten según la política.

V09. Auditoría DDL omitida silenciosamente

Prioridad media · OWASP A09/A10 · Confirmado por consulta y código instalado.

En el servidor de la base académica, `DB_ID('INTEC_INTEGRACION_CONTROL')` devolvió NULL. El trigger `trg_AUD_DDL_IntegracionTotal` permanece habilitado, pero la corrección local `backend/sql/2026_09_20_auditoria_ddl_tolerante.sql:14` retorna si esa base no existe. El bloque CATCH también retorna sin alertar.

La corrección permite que las migraciones funcionen, pero no restablece el registro de esos eventos DDL. No se afirma que toda la auditoría de aplicación o de movimientos esté ausente: este hallazgo se limita al trigger examinado.

Recomendación: destino de auditoría válido en el servidor correspondiente o almacenamiento durable alternativo con envío posterior, junto con alertas de indisponibilidad. Criterio de cierre: una migración autorizada en un entorno de prueba produce el evento trazable y la pérdida del destino genera una alerta verificable sin depender de silencios en CATCH.

V10. Cobertura incompleta de análisis de archivos

Prioridad media · OWASP A02/A08 · Desactivación local confirmada; controles cloud no verificados.

Se observó `UPLOAD_ANTIMALWARE_ENABLED=false`; `backend/app/core/file_security.py:147` omite la comprobación del analizador cuando está desactivado. Sí existen límites de tamaño, comprobaciones de extensión/firma y controles de archivos comprimidos.

Las cargas directas a Graph en `routers/document_expedients.py:1284` y `:1368`, con finalización en `services/graph_documents.py:727`, aceptan metadatos/tamaño sin un estado de cuarentena que confirme análisis y formato real. Inglés agrega otros controles de metadatos, tamaño y hash, pero no acredita análisis antimalware en `routers/english_exams.py:3119`. Microsoft 365 puede aplicar protección propia; su política y cobertura no se verificaron.

Recomendación: activar y supervisar análisis local donde el archivo pasa por el backend, y exigir verificación equivalente antes de publicar cargas directas. Criterio de cierre: documentos quedan pendientes hasta obtener el resultado de análisis/formato y no se distribuyen archivos rechazados. Activar solo el antivirus local no cubre la subida directa a Graph. OWASP: carga de archivos.

V11. Perfil de desarrollo y acceso alternativo HTTP

Prioridad media · OWASP A02 · Confirmado en configuración y respuestas HTTP.

La configuración cargada por el proyecto es `APP_ENVIRONMENT=development`. Por ello, `backend/app/core/config.py:368` omite la validación estricta prevista para producción. Se observaron `trusted_hosts=*`, documentación habilitada y `csrf_require_origin=false`.

El sitio principal redirige HTTP a HTTPS y aplica varias cabeceras defensivas, pero no devuelve HSTS. El sitio auxiliar `backendacad`, puerto 89, publica `/docs` y `/openapi.json` mediante HTTP, con respuesta 200 tanto por localhost como por el dominio desde este servidor. `backend/web.config:6` reenvía toda ruta al backend sin imponer HTTPS. La accesibilidad desde otra red queda pendiente de verificación; no se expusieron registros personales en esas solicitudes.

Recomendación: preparar los requisitos de producción, restringir el sitio auxiliar a uso interno, deshabilitar documentación pública, fijar hosts/orígenes HTTPS y publicar HSTS en IIS para el HTML además de en la API. Criterio de cierre: perfil productivo inicia con todos los controles satisfechos; no hay acceso HTTP alternativo público y el sitio HTTPS devuelve HSTS. No cambiar únicamente la variable de entorno: el arranque rechazará las opciones inseguras actuales.

V12. Componentes Python con avisos de seguridad

Prioridad alta · OWASP A03 · Versiones afectadas confirmadas; explotación no ejecutada.

El inventario instalado contiene seis avisos únicos en cuatro paquetes. Los diez registros brutos del escáner incluyen duplicados. La prioridad inmediata es Starlette 1.2.1: el aviso CVE-2026-54283 describe agotamiento de recursos al analizar formularios. FastAPI instalado analiza formularios antes de resolver dependencias de autorización; hay endpoints [Form/File](#) en el proyecto. Esto hace relevante el aviso incluso con rutas protegidas. No se envió ninguna carga DoS. Corregido por el fabricante en Starlette 1.3.1. [Aviso oficial](#).

AnyIO 4.13.0 tiene un aviso crítico del fabricante sobre validación TLS para determinados nombres internacionales. No se demostró que el proyecto alcance sus condiciones de explotación. Tiene también un aviso de disponibilidad de workers. Las versiones corregidas indicadas por el escáner son 4.14.2. El inventario detallado está en la sección 5. [Aviso oficial TLS de AnyIO](#).

Recomendación: resolver y probar una combinación compatible de FastAPI/Starlette/AnyIO, registrar las versiones transitivas, reconstruir el entorno y separar utilidades de instalación del runtime. Criterio de cierre: el inventario realmente desplegado deja de coincidir con los avisos aplicables y pasa pruebas de formularios, uploads y sesiones. No basta auditar únicamente las dependencias directas.

V13. Dependencias del frontend Angular legado

Prioridad media por exposición no demostrada · OWASP A03 · Alertas confirmadas en su lockfile.

`frontend-angular/package-lock.json` reporta 24 paquetes afectados: 11 de severidad alta, 12 moderada y 1 baja según npm. Al omitir dependencias de desarrollo quedan 8 paquetes: 3 altos y 5 moderados. Son conteos de paquetes afectados, no 24 CVE únicos. El sitio IIS actual sirve el frontend React, cuyo escaneo reportó cero alertas.

Recomendación: confirmar si Angular sigue utilizándose; si se mantiene, actualizar su árbol y probarlo antes de volver a publicar. Si está retirado, documentar esa condición y evitar desplegarlo accidentalmente. Criterio de cierre: inventario vigente sin avisos aplicables o retirada verificable. No se atribuyen estas alertas al frontend React en producción.

El análisis señala Angular core/common/compiler 20.3.25; los avisos consultados indican correcciones en la familia 20.3.28. DOMPurify 3.4.11 aparece como dependencia transitiva opcional de jsPDF, con corrección en 3.4.13. La pertinencia de avisos de SSR/HttpTransferCache y de DOMPurify depende del uso; no se encontró ese uso específico en el muestreo del código cliente. [Angular: aviso de XSS](#), [DOMPurify: aviso](#).

V14. Reutilización del secreto de integración para sesiones

Prioridad media · OWASP A04/A02 · Confirmado sin mostrar el secreto.

La configuración no contiene un secreto independiente de sesión. `backend/app/core/config.py:350` usa `client_secret` como alternativa en modo desarrollo. Se verificó que la clave efectiva tiene al menos 32 caracteres; el problema no es su longitud sino la falta de separación de funciones.

La exposición o rotación del secreto de integración puede afectar también a las cookies firmadas. Su conocimiento permitiría intentar falsificar tokens de la aplicación; no se probó falsificación contra producción.

Recomendación: secreto aleatorio dedicado de sesión, custodia separada y rotación controlada que invalide las sesiones anteriores. Criterio de cierre: la aplicación requiere `SESSION_SECRET` explícito y la clave de Graph no permite firmar sesiones válidas.

5. Inventario de dependencias y verificación

Alcance auditado	Resultado	Interpretación
Frontend React activo	0 vulnerabilidades reportadas	Estado del registro al escanear; no prueba ausencia de fallos de código
Requisitos Python directos	29 auditados, 0 avisos	No cubre por sí solo las dependencias transitivas instaladas
Entorno Python instalado	82 auditados; 4 paquetes, 6 avisos únicos	10 registros brutos por duplicación de identificadores
Angular legado, árbol completo	24 paquetes afectados	11 altos, 12 moderados, 1 bajo
Angular legado, sin desarrollo	8 paquetes afectados	3 altos, 5 moderados

Las severidades de los seis avisos Python, según los advisories consultados, son una crítica, una alta, tres medias y una baja. Son severidades del componente; no equivalen a seis ataques demostrados en este despliegue.

Componente instalado	Aviso único	Versión corregida indicada
AnyIO 4.13.0	CVE-2026-63374 / GHSA-82r6-8w77-94w6	4.14.2
AnyIO 4.13.0	CVE-2026-64847 / GHSA-5p39-cfhj-2xmp	4.14.2
Starlette 1.2.1	CVE-2026-54283 / GHSA-82w8-qh3p-5jfq	1.3.1
Starlette 1.2.1	CVE-2026-54282 / GHSA-jp82-jpqv-5vv3	1.3.0; usar una versión que corrija ambos avisos
pip 26.1.2	CVE-2026-13346 / GHSA-qwm4-qh6w-59xr	26.2
setuptools 82.0.1	CVE-2026-59890 / GHSA-h35f-9h28-mq5c	83.0.0

pip y setuptools son herramientas de instalación/construcción, no endpoints. El aviso de setuptools requiere un contexto macOS que no corresponde al servidor Windows observado. El aviso de workers AnyIO depende del uso del camino afectado; no se halló invocación directa de [anyio.to_process](#) en la aplicación. Se conserva su inventario para la actualización de dependencias sin exagerar el riesgo productivo. La compatibilidad de las versiones recomendadas deberá validarse antes de instalarlas.

Los JSON originales se incluyen en [evidencias/](#), con nombres de paquetes, versiones y avisos públicos. No contienen credenciales ni datos académicos. La salida de los escáneres es evidencia, no una instrucción de aplicar automáticamente [audit fix](#).

6. Estado observado de controles

Control	Evidencia y límite
TLS del sitio principal	TLS 1.0/1.1 rechazados; 1.2/1.3 aceptados con certificado verificado en puerto 443
Certificado HTTPS	Caducidad observada: 3 de noviembre de 2026, 15:42:49 UTC
Cifrados negociados	TLS 1.2: ECDHE-RSA-AES256-GCM-SHA384; TLS 1.3: TLS_AES_256_GCM_SHA384; no se enumeraron todos los cifrados
Redirección	HTTP principal devuelve 301 a HTTPS
Cabeceras	CSP, nosniff, DENY, Referrer-Policy y Permissions-Policy presentes; HSTS ausente
Sesión	Cookie Secure/SameSite=Lax; HttpOnly en código; JWT valida algoritmo, emisor, audiencia y tiempos
Acceso anónimo	/api/auth/me y una ruta ficticia de uploads devuelven 401
Errores	Detalles 5xx sustituidos por mensaje con código de seguimiento cuando <code>expose_internal_errors=false</code>
SQL	Uso de parámetros y catálogos permitidos en flujos revisados; no se confirmó inyección SQL
Archivos	Contención de rutas, límites, firmas y controles ZIP existentes; autorización por archivo y malware pendientes
Moodle	Validación del origen y redirecciones de archivos; verificación TLS habilitada
Frontend	React sin <code>dangerouslySetInnerHTML</code> encontrado; vista HTML Moodle usa iframe aislado; sesión principal mediante cookie
Ingreso directo	Transacción, bloqueo e idempotencia por solicitud/operador; credenciales requieren perfil administrador
Automatización	Workflows para pruebas, análisis de dependencias, CodeQL y secretos presentes; no se verificó ejecución remota reciente

No se encontraron archivos `.env` productivos o certificados privados versionados mediante la comprobación de rutas Git realizada; sí hay archivos de ejemplo. Esto no sustituye un escaneo del contenido y de todo el historial en busca de secretos.

7. Relación con OWASP Top 10:2025

El mapeo usa la [edición oficial 2025](#) y orienta la revisión; no expresa porcentajes de cumplimiento.

Categoría	Estado de esta revisión
A01 Control de acceso	V01, V02 y V03; requieren corrección y pruebas entre roles/usuarios
A02 Configuración	V06, V10, V11 y V14; configuración productiva insuficiente
A03 Cadena de suministro	V12 y V13; avisos del inventario y falta de cobertura transitiva completa
A04 Criptografía	V05, V07 y V14; claves locales, transporte SQL y separación de secretos
A05 Inyección	No confirmada en el muestreo; no se realizó fuzzing ni revisión exhaustiva
A06 Diseño	V04 y V03; identidad y credenciales requieren decisiones de diseño

Categoría	Estado de esta revisión
A07 Autenticación	V03, V04, V05 y V08; suplantación, claves y revocación
A08 Integridad	V10; verificar el archivo real antes de publicarlo; alcance cloud pendiente
A09 Registro y alertas	V09; el trigger habilitado no garantiza que se registre el evento
A10 Condiciones excepcionales	V09 y V12; retorno silencioso y consumo de recursos; errores 5xx sí enmascarados

8. Plan propuesto de corrección

Prioridad inmediata: primeras 24 a 72 horas

- Equipo backend: cerrar V01, V02 y V03 con controles por operación, propietario e identidad, y pruebas de rechazo entre perfiles.
- Identidad y sistemas: sustituir V04 mediante entrega de credenciales temporales aleatorias y plan de restablecimiento; preparar la migración de V05.
- Backend y despliegue: actualizar la combinación vulnerable de formularios Starlette y resolver AnyIO, con inventario desplegado verificable (V12).
- Operación: configurar revocación compartida para V08 y planificar la invalidación de sesiones anteriores.

Primera semana

- DBA y sistemas: habilitar y verificar cifrado SQL, separar permisos de aplicación/migración y retirar SYSTEM como identidad de ejecución (V06, V07).
- Backend y operación: separar el secreto de sesión y preparar todos los requisitos del perfil productivo antes de activarlo (V11, V14).
- DBA: restaurar el destino de auditoría DDL o una alternativa durable con alertas (V09).

Dos a cuatro semanas

- Completar hash de contraseñas en todas las rutas y aplicaciones dependientes (V05).
- Implementar análisis y cuarentena coherentes para archivos locales y directos a Graph (V10).
- Actualizar o retirar Angular legado, generar un inventario reproducible/SBOM y automatizar revisión del entorno realmente desplegado (V13, V12).
- Repetir las pruebas de autorización, sesiones y TLS desde una red independiente, y ejecutar un escaneo de secretos del historial con resultados redactados.

Los plazos son prioridades sugeridas, no una estimación contractual. Cada cambio debe tener respaldo, pruebas proporcionales y reversión prevista. No se recomienda habilitar en bloque la configuración de producción antes de preparar sus dependencias, porque el validador actual rechazaría el arranque.

9. Evidencias y referencias

Evidencias incluidas: cinco resultados JSON de auditoría de dependencias, [evidencias/configuracion_observada.json](#) con valores permitidos y un manifiesto SHA-256 para identificar los archivos examinados. Las referencias [archivo:línea](#) corresponden al commit indicado; cambiarán al modificar el código. El informe PDF y este Markdown tienen el mismo contenido principal.

Fuentes técnicas primarias consultadas el 21 de septiembre de 2026:

- [OWASP Top 10:2025](#).
- [OWASP: autorización](#), para controles por operación y objeto.
- [OWASP: autenticación y almacenamiento de contraseñas](#).
- [OWASP: carga de archivos](#).
- [Microsoft: cifrado ODBC](#).
- [Starlette: formularios y consumo de recursos y autoridad de URL](#).
- [AnyIO: validación TLS y bloqueo de workers](#).
- [pip: aviso GHSA-qwm4-qh6w-59xr](#).
- [setuptools: aviso GHSA-h35f-9h28-mq5c](#).

El objetivo de esta entrega es permitir revisar y asignar las correcciones. No se infiere que haya ocurrido una intrusión, una fuga de datos o una explotación real de los hallazgos.